Portfolio Lab on WPScan for Penetration Testing of a WordPress Site

This lab will guide you through setting up a WordPress security assessment lab using WPScan on a Kali Linux virtual machine (VM) and a WordPress VM. You will learn how to configure the environment, install the necessary tools, and use WPScan to explore different scanning options against a WordPress installation.

WPScan is a powerful tool used to scan WordPress websites for security vulnerabilities, themes, plugins, and configuration weaknesses.

Primary Learning Outcome

LO3: Evaluate risks to privacy and anonymity in commonly used applications.

Lab Setup Requirements

Prerequisites

- **VirtualBox** installed on your machine.
- Two VMs:
  1. **Kali Linux VM**: For running WPScan and performing security assessments.
  2. **WordPress VM**: An instance with WordPress installed, configured as a target for scanning.

Step 1: Setting Up the Kali Linux VM

1. **Get WPScan API Key**:
   - Register for a free WPScan API key to access the vulnerability database from https://wpscan.com/register.

- Save the API key; you'll use it in the scanning commands.

Step 2: Setting Up the WordPress VM

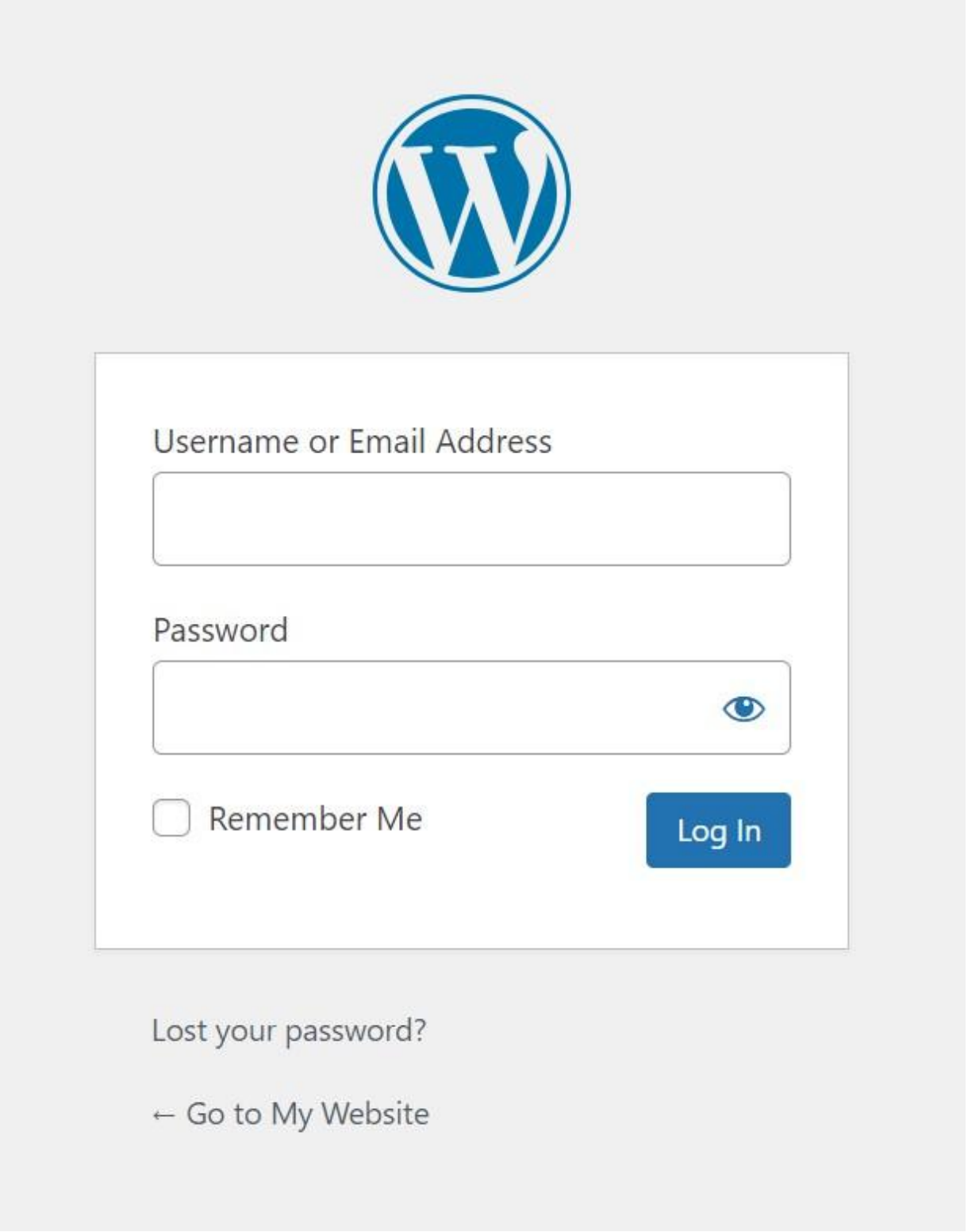
1. Download a Preconfigured WordPress VM from the Cyber Lab VM Repository
    - Download a WordPress ova file from here: Virtual Machines.

Step 3: Ensure that the Kali VM can communicate with the WordPress VM

1. **Start both VMs**:
    - Make sure that both virtual machines can ping each other successfully
2. **Make sure that your Kali virtual machine can browse to the WordPress virtual machine.** :
    - Use the `ifconfig` , `ip addr` or `ip a` command on the WordPress VM to determine its IP address if required.

    - From the Kali virtual machine, open a web browser and enter the IP address of your WordPress virtual machine.
3. **Browse to the admin pages of WordPress and create a user with a weak password.** :
    - From the Kali virtual machine open a web browser and enter the IP address of the WordPress virtual machine, appended with /wp-admin. For example: **192.168.123.xxx/wp-admin**

- A page similar to that shown below should appear:



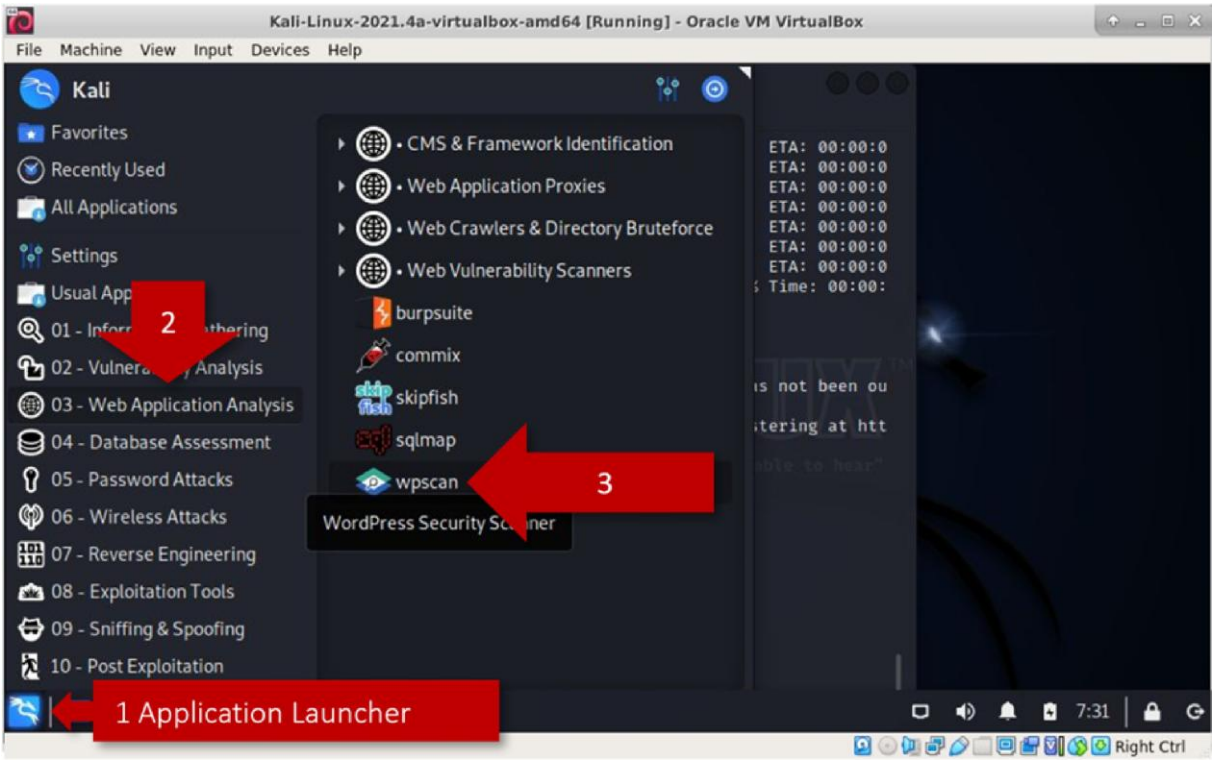
- Login and create a new user with admin privileges. Ensure that the new user has a weak password. For example, you can try using a password from some examples here: https://en.wikipedia.org/wiki/List_of_the_most_common_passwords
- Once you have created the new user, test it!!!

Step 4: Can you add a vulnerable theme and plugin to WordPress?

1. Research vulnerable WordPress themes. See if you can add a vulnerable theme to WordPress.
2. Research vulnerable WordPress plugins. See if you can add a vulnerable plugin to WordPress.

Step 5: Update WPScan

1. On your Kali virtual machine, select the Kali Applications Launcher > select 03 – Web Application Analysis > wpscan as indicated in the image below.



This will open a new terminal window. From the wpscan terminal type:

```
wpscan --update
```

WPScan Lab Exercises

1. Vulnerability Database Update and Plugin Enumeration

Before a vulnerability scan, update the WPScan vulnerability database using your API key:

```
wpscan --api-token YOUR_API_KEY --update
wpscan --url http://<wordpress_ip> --enumerate p
```

- **Explanation**: WPScan checks its vulnerability database for the latest issues and then enumerates installed plugins (`p`). Knowing the plugins helps identify possible attack vectors since plugins often have vulnerabilities.

2. Full Scan for Plugins, Themes, and WordPress Version Detection

Perform a comprehensive scan that targets plugins, themes, and the WordPress version.

```
wpscan --url http://<wordpress_ip> --enumerate vp,vt,tt
```

- **Explanation**:
  - `vp`: Enumerates vulnerable plugins.
  - `vt`: Enumerates vulnerable themes.
  - `tt`: Enumerates themes and attempts to find vulnerabilities associated with them.
  - This scan is more thorough and can take some time but provides essential information about potential vulnerabilities in plugins, themes, and the core WordPress version.

3. Brute Forcing Login Passwords

If usernames are discovered, you can perform a brute-force password attack. **(Ensure you have authorisation to perform this on the target system.)**

1. Download a file called ***10000_common_passwords.txt*** from the Cyber Lab VM Repository. You will need to get this file on to your Kali VM.
2. Run the brute-force scan with the following command:

   ```
   wpscan --url http://<wordpress_ip> --passwords passwords.txt --username <username>
   ```

- **Explanation**: This command will attempt to log in to WordPress with a list of passwords for the given username. Be mindful that brute-forcing can be slow, depending on the password list's length.

4. Scanning with API Key for Detailed Vulnerabilities

To find detailed vulnerability information, use your WPScan API key:

```
wpscan --api-token YOUR_API_KEY --url http://<wordpress_ip> --enumerate ap
```

- **Explanation**: The `ap` option enumerates all plugins and checks each plugin against the WPScan vulnerability database. Using the API key enables access to the latest vulnerability information.

5. Excluding Specific Scans and Setting a Delay

If you want to avoid certain types of scans or slow down the scanning process, use exclusion and delay options:

```
wpscan --url http://<wordpress_ip> --enumerate vp,vt --throttle 0.5
```

- **What is the aim of Point 5?**

  1. **Exclude Specific Types of Scans**
  2. **Throttle Requests by Adding a Delay**

  This setup is designed to achieve two main objectives:

---

1. Selective Scanning: Excluding Specific Scans

- **Aim**: By specifying only certain scan types (in this case, vulnerable plugins `vp` and themes `vt`), the scan becomes more targeted.
- **Benefits**:
  - **Focus on High-Risk Areas**: Limiting scans to plugins and themes focuses WPScan's efforts on the components most likely to have vulnerabilities in a WordPress installation. Plugins and themes often introduce vulnerabilities because they are frequently updated and sometimes contain exploitable code.
  - **Reduce Scan Time**: Scanning only for specific items (like plugins and themes) reduces the time needed to complete the scan, as it avoids unnecessary checks (such as user enumeration or core version detection).
  - **Limit System Load**: Fewer scan types mean fewer requests to the target WordPress site, which reduces the impact on server resources and network traffic.

2. Adding a Delay Between Requests

- **Aim**: The `--throttle` option (set to 0.5 seconds in this case) introduces a delay between each HTTP request sent by WPScan.
- **Benefits**:
  - **Avoid Detection**: Many security systems monitor the frequency of requests. Rapid-fire scanning is more likely to trigger intrusion detection/prevention systems or firewall rules. Adding a delay makes the scan appear more like regular user traffic.
  - **Prevent Rate-Limiting Blocks**: Some sites implement rate-limiting to prevent excessive requests in a short time. Introducing a delay helps avoid hitting these limits, allowing the scan to proceed without interruption.
  - **Reduce Server Strain**: Delaying requests is considerate to the target server, especially for production sites, as it reduces the load and helps maintain normal site performance during scanning.

Ultimately, the aim of point 5 is to perform a **stealthier, more targeted scan** by:

- Focusing only on the most critical parts of the WordPress site (plugins and themes) where vulnerabilities are most commonly found.
- Slowing down the request rate to reduce the likelihood of detection, avoid rate-limiting restrictions, and lower the impact on the target server.

This approach is particularly useful in real-world scenarios where maintaining a low profile is essential or when scanning a production site where minimising disruption is a priority.

Summary of WPScan Options

Command	Description
`--enumerate u`	Enumerate usernames.
`--enumerate p`	Enumerate plugins.
`--enumerate vp`	Enumerate vulnerable plugins.
`--enumerate vt`	Enumerate vulnerable themes.
`--enumerate tt`	Enumerate themes.
`--enumerate ap`	Enumerate all plugins.
`--passwords <file>`	Use a password list for brute-force attacks.
`--user-agent <string>`	Use a custom User-Agent string.
`--proxy <proxy_ip:proxy_port>`	Route traffic through a specified proxy.
`--throttle <seconds>`	Delay between requests.
`--api-token <api_key>`	Use API key to access vulnerability database.

Portfolio Deliverable

Complete this lab and provide screenshots and explanation as part of your coursework.

End of Lab